

POST-QUANTUM CRYPTOGRAPHY READINESS ASSESSMENT

Programme	Enterprise Cryptographic Risk Management Program
Phase	Phase 5 - Post-Quantum Cryptography Readiness Assessment
Document Owner	Cryptography Security Analyst
Scope	Enterprise Digital Certificate Estate
Standards	NIST FIPS 203 (ML-KEM), FIPS 204 (ML-DSA), FIPS 205 (SLH-DSA)
Version	1.0
Date	04 June 2026
Status	For Internal Review

Table of Contents

- 1. Executive Summary
- 2. The Quantum Threat to Cryptography
- 3. Current Cryptographic Exposure
- 4. NIST Post-Quantum Cryptography Standards
- 5. PQC Migration Roadmap
- 6. Crypto Agility Framework
- 7. Recommendations
- 8. Document Control

SECTION 1

Executive Summary

The emergence of quantum computing poses a fundamental threat to all currently deployed asymmetric cryptography. Quantum computers, leveraging Shor's algorithm, will be capable of breaking RSA, ECC and DSA algorithms - rendering today's certificates, encrypted communications and digital signatures cryptographically worthless.

A cryptographic asset assessment of the enterprise certificate estate identified 15 digital certificates, all of which rely on quantum-vulnerable algorithms - RSA and ECC. While 11 certificates currently meet NIST SP 800-57 classical security thresholds, all 15 are vulnerable to a sufficiently powerful quantum computer.

Additionally, the Harvest Now, Decrypt Later threat means adversaries may already be collecting encrypted enterprise data today, intending to decrypt it once quantum computing becomes available - making immediate action critical regardless of when quantum computers arrive.

This assessment recommends a phased migration to NIST-standardised post-quantum algorithms - ML-KEM, ML-DSA and SLH-DSA - prioritising the most sensitive and long-lived assets first, and establishing a crypto agility framework to enable rapid algorithm replacement across the enterprise.

Finding	Detail
Certificates Assessed	15 digital certificates across the enterprise estate
Quantum Vulnerability	100% - all certificates rely on quantum-vulnerable algorithms
Algorithms at Risk	RSA (11 certs), ECC (4 certs)
Active Threat	Harvest Now, Decrypt Later - data collection already occurring
Migration Target	ML-KEM (FIPS 203), ML-DSA (FIPS 204), SLH-DSA (FIPS 205)
Overall Risk Rating	Critical - immediate planning required

SECTION 2

The Quantum Threat to Cryptography

2.1 Why Quantum Computing Changes Everything

Classical computers process information as bits - values of either 0 or 1. Quantum computers use qubits, which can exist as 0, 1 or both simultaneously - a property called superposition. Combined with entanglement and interference, this gives quantum computers the ability to perform certain calculations exponentially faster than any classical computer.

Today's asymmetric cryptography - RSA, ECC and DSA - is secure because the mathematical problems it relies on are practically impossible for classical computers to solve. A quantum computer running Shor's algorithm changes this entirely - it can break RSA-2048 in hours rather than billions of years.

2.2 Harvest Now, Decrypt Later

Nation-state adversaries and sophisticated threat actors do not need a quantum computer today to begin exploiting this vulnerability. The strategy known as Harvest Now, Decrypt Later involves collecting and storing encrypted enterprise data now - TLS traffic, signed documents, encrypted communications - with the intention of decrypting it once quantum computing becomes available.

This means organisations that handle sensitive, long-lived data - financial records, personal data, intellectual property, government communications - are already at risk today, even before a single quantum computer capable of breaking encryption exists.

2.3 The Migration Window is Now

NIST completed its post-quantum cryptography standardisation process in 2024, publishing three approved algorithms - ML-KEM, ML-DSA and SLH-DSA. Cryptographic migrations historically take 10 to 15 years to complete across large enterprises. Given that quantum computers capable of breaking current encryption are estimated to arrive within the next 10 to 15 years, the migration window has effectively already opened.

Organisations that begin their PQC migration now will transition in an orderly, controlled manner. Those that delay risk emergency, costly and error-prone migrations under time pressure.

SECTION 3

Current Cryptographic Exposure

3.1 Inventory Overview

A cryptographic asset assessment was conducted across the enterprise certificate estate as part of Phase 1 of the Enterprise Cryptographic Risk Management Program, inventorying 15 digital certificates and evaluating each against NIST SP 800-57 classical cryptographic standards.

Metric	Value
Total Certificates Inventoried	15
Valid Certificates	11 (73%)
Expired Certificates	4 (27%)
Strong Key Certificates (Classical)	13 (87%)
Weak Key Certificates (Classical)	2 (13%)
Certificates Expiring Within 30 Days	0 (0%)

3.2 Algorithm Distribution

Algorithm	Count	Percentage	Quantum Vulnerable?
RSA	11	73%	Yes - broken by Shor's algorithm
ECC	4	27%	Yes - broken by Shor's algorithm
DSA	0	0%	Yes - broken by Shor's algorithm

3.3 Quantum Vulnerability Finding

While 87% of certificates meet classical cryptographic strength standards, all 15 certificates rely on quantum-vulnerable algorithms. From a post-quantum perspective, the classical distinction between Strong and Weak keys is rendered irrelevant - RSA-4096 is no more quantum-resistant than RSA-1024 against Shor's algorithm. This represents a critical enterprise-wide exposure requiring full migration to post-quantum algorithms.

3.4 Assessment Scope Note

This assessment covers the enterprise digital certificate estate only - Phase 1 of a broader cryptographic inventory programme. A comprehensive PQC readiness assessment would additionally cover cryptographic libraries, TLS configurations, SSH keys, IPSec tunnels, API tokens and database encryption. These asset classes are planned for subsequent assessment phases.

SECTION 4

NIST Post-Quantum Cryptography Standards

4.1 Background

In August 2024, NIST finalised its post-quantum cryptography standardisation process - the result of an 8-year global evaluation involving cryptographers from over 25 countries. Three algorithms were approved as the foundation for post-quantum cryptographic migration, based on mathematical problems believed to be resistant to both classical and quantum attacks.

4.2 Approved PQC Algorithms

Algorithm	Former Name	Purpose	Replaces
ML-KEM (FIPS 203)	Kyber	Key Encapsulation / Key Exchange	RSA and ECC key exchange
ML-DSA (FIPS 204)	Dilithium	Digital Signatures	RSA and ECC signatures
SLH-DSA (FIPS 205)	SPHINCS+	Digital Signatures (hash-based)	RSA and ECC signatures

4.3 What Each Algorithm Does

ML-KEM - Module Lattice Key Encapsulation Mechanism

Used for securely establishing shared encryption keys between two parties - replacing RSA and ECC in TLS handshakes and key exchange protocols. Primary algorithm for securing encrypted communications.

ML-DSA - Module Lattice Digital Signature Algorithm

Used for creating and verifying digital signatures - replacing RSA and ECC in certificate signing, code signing and authentication. Primary algorithm recommended for certificate migration.

SLH-DSA - Stateless Hash-Based Digital Signature Algorithm

A hash-based signature scheme providing an alternative to ML-DSA. Recommended as a secondary signature algorithm for high-assurance environments.

4.4 Relevance to This Assessment

For the enterprise certificate estate identified in Phase 1, the primary migration target is ML-DSA - as certificates are predominantly used for digital signatures and authentication. Key exchange mechanisms will migrate to ML-KEM as TLS and protocol configurations are updated in subsequent phases.

SECTION 5

PQC Migration Roadmap

5.1 Migration Principles

- Prioritise by sensitivity - migrate assets handling the most sensitive or long-lived data first
- Crypto agility first - ensure systems can swap algorithms without architectural redesign
- Hybrid approach - run classical and PQC algorithms in parallel during transition
- No big bang - phased migration reduces risk and allows lessons learned at each stage

5.2 Phased Migration Plan

Phase	Timeline	Scope	Action
Phase 1 - Discovery	Now - 3 months	All crypto assets	Complete enterprise-wide crypto inventory covering certificates, libraries, protocols and key stores
Phase 2 - Prioritisation	3 to 6 months	High sensitivity	Identify and prioritise assets handling sensitive, long-lived or regulated data
Phase 3 - Pilot	6 to 12 months	Non-critical systems	Migrate selected non-critical systems to PQC - build internal capability
Phase 4 - Hybrid	12 to 24 months	Business critical	Deploy hybrid classical and PQC certificates across business critical systems
Phase 5 - Full PQC	24 to 36 months	All assets	Complete migration of all certificates, protocols and key stores
Phase 6 - Decommission	36 months+	Enterprise wide	Retire all RSA, ECC and DSA based cryptographic assets

5.3 Certificate Migration Priority

Priority	Certificate Type	Rationale
1 - Immediate	Expired certificates (4)	Already non-compliant - remediate under Phase 3 process first
2 - High	Root CA certificates	Long-lived, high trust anchor - quantum compromise has cascading impact
3 - High	External facing certs	Directly exposed to Harvest Now Decrypt Later attacks
4 - Medium	Internal certificates	Lower exposure but still require migration
5 - Planned	All remaining certs	Full migration by end of Phase 5

5.4 Hybrid Cryptography Approach

During the transition period, a hybrid approach is recommended - combining classical and post-quantum algorithms in the same certificate or handshake. This ensures backwards compatibility, quantum resistance for supporting systems, and a gradual low-risk migration path. Hybrid certificates combining RSA-2048 with ML-DSA are recommended as the interim standard during Phases 3 and 4.

SECTION 6

Crypto Agility Framework

6.1 What is Crypto Agility?

Crypto agility is the ability of an organisation's systems, applications and infrastructure to rapidly swap cryptographic algorithms, key sizes or protocols without requiring significant architectural redesign or system downtime. It is the foundational capability that enables rapid response to newly discovered vulnerabilities, regulatory changes, and the quantum threat.

6.2 Crypto Agility Maturity Model

Level	Maturity	Description
Level 1	Initial	No crypto inventory. Algorithm changes require full system redesign. Migration timelines measured in years.
Level 2	Developing	Partial inventory exists. Some systems support algorithm configuration. Migration is manual and slow.
Level 3	Defined	Full crypto inventory maintained. Algorithm parameters are configurable. Migration process is documented.
Level 4	Managed	Automated inventory and monitoring. Algorithm changes deployed via pipeline. KPIs tracked.
Level 5	Optimised	Fully automated crypto lifecycle. Real-time posture visibility. PQC algorithms deployed and monitored continuously.

6.3 Current Maturity Assessment

Based on the work completed across Phases 1 to 4 of the Enterprise Cryptographic Risk Management Program, the organisation is currently assessed at Level 2 to 3 - Developing to Defined.

Capability	Current Status
Cryptographic Inventory	Partially complete - certificates inventoried, libraries and protocols pending
Automated Scanning	Implemented via Phase 1 Python tool
Posture Dashboard	Implemented via Phase 2 HTML dashboard
Vulnerability Management	Documented via Phase 4 process
PQC Algorithm Support	Not yet implemented
Algorithm Configurability	Unknown - requires further assessment

6.4 Crypto Agility Target State

To achieve Level 4 maturity and support PQC migration, the following capabilities must be developed:

- Centralised Certificate Lifecycle Management - automated issuance, renewal and revocation
- Algorithm Abstraction Layer - applications reference a cryptographic service rather than hardcoding algorithms
- Automated Compliance Monitoring - continuous scanning against NIST PQC standards with real-time alerting
- PQC Library Integration - cryptographic libraries updated to support ML-KEM, ML-DSA and SLH-DSA
- Hybrid Certificate Support - infrastructure capable of handling hybrid classical and PQC certificates

SECTION 7

Recommendations

7.1 Immediate Actions (0 to 3 months)

Priority	Recommendation	Rationale
1	Remediate all 4 expired certificates per Phase 3 process	Active security risk independent of quantum threat
2	Remediate 2 weak key certificates (RSA-1024)	Below NIST classical threshold - immediate compliance risk
3	Extend crypto inventory to libraries, protocols, SSH keys, key stores	Complete visibility required before migration planning
4	Brief CISO on PQC threat timeline and migration requirements	Executive awareness and budget commitment required

7.2 Short Term Actions (3 to 12 months)

Priority	Recommendation	Rationale
5	Assess all systems for PQC algorithm support and crypto agility	Identifies systems requiring architectural changes
6	Begin pilot PQC migration on non-critical systems using ML-DSA	Build internal capability at low risk
7	Evaluate PQC-capable Certificate Authority and PKI platform	Current CA must support ML-DSA and hybrid certificates
8	Implement centralised certificate lifecycle management	Enables automated PQC compliance monitoring

7.3 Medium Term Actions (12 to 36 months)

Priority	Recommendation	Rationale
9	Deploy hybrid classical and PQC certificates on critical systems	Maintains compatibility while introducing quantum resistance
10	Update cryptographic libraries to support ML-KEM, ML-DSA, SLH-DSA	Foundation for application-level PQC adoption
11	Migrate all external facing certificates to ML-DSA	Highest exposure to Harvest Now Decrypt Later attacks
12	Achieve crypto agility Level 4 maturity	Enables rapid response to future cryptographic threats

7.4 Summary Risk Statement

The enterprise cryptographic estate is currently 100% quantum-vulnerable.

While classical security thresholds are largely met, the arrival of quantum computing - combined with the active Harvest Now Decrypt Later threat - requires immediate action. The window for orderly, controlled migration is open now. Delay increases the likelihood of emergency, costly and incomplete migration under time pressure.

The recommended overall posture is: Act now. Migrate early. Build crypto agility.

SECTION 8

Document Control

Document Title	Post-Quantum Cryptography Readiness Assessment
Document Owner	Cryptography Security Analyst
Programme	Enterprise Cryptographic Risk Management Program
Version	1.0
Status	For Internal Review
Created	04 June 2026
Review Frequency	Annually or following NIST PQC standards updates
Next Review Date	June 2027
Approved By	CISO (Pending Approval)

Version History

Version	Date	Author	Changes
1.0	04 June 2026	Cryptography Security Analyst	Initial draft